

Web Technologies & Web Security

מאור אבוטבול

09.06.2026

#Who am I

מי אני

- אבא, מהנדס, חוקר, גיימר
- ~20 שנים בעולמות הסקיוריטי
- גדלתי ב

<https://il.linkedin.com/in/maor-abutbul>



- היום - חוקר חולשות – פאלו אלטו נטוורקס
- Idira Labs לשעבר Cyberark
- הצוות שלי



Agenda

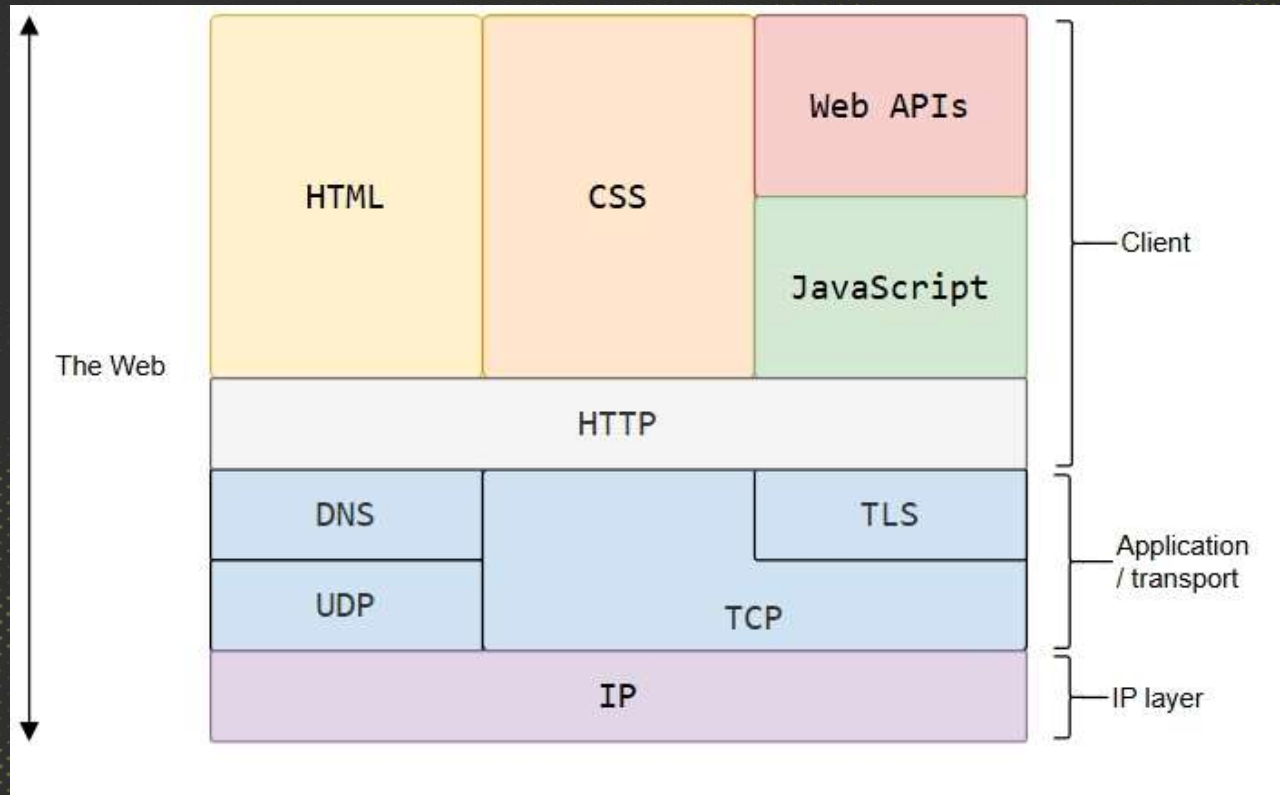
- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב (Web Security)
- חולשה נפוצה + מעבדה עצמית
- מקורות תרגול והעשרה

Web Technologies ווב טכנולוגיות

HTML · CSS · JavaScript



Web Technologies / Layers



HTML — HyperText Markup Language

- HTML is the standard markup language for creating Web pages.

```
<!DOCTYPE html>
<html>
<head>
<title>Page Title</title>
</head>
<body>

<h1>This is a Heading</h1>
<p>This is a paragraph.</p>

</body>
</html>
```

This is a Heading

This is a paragraph.

- <https://www.w3schools.com/html/default.asp>

JavaScript

- The world's most popular programming language. JavaScript is the programming language of the Web.

- הרצת קוד בצד לקוח (דפדפן)

```
<!DOCTYPE html>
<html>
<body>

<h2>My First JavaScript</h2>

<button type="button"
onclick="document.getElementById('demo').innerHTML =
Date()">
Click me to display Date and Time.</button>

<p id="demo"></p>

</body>
</html>
```

My First JavaScript

Click me to display Date and Time.

Sun Jun 27 2021 12:17:51 GMT+0300 (Israel Daylight Time)

<https://www.w3schools.com/js/default.asp>

Server-side and client-side technologies

- Front-end - client-side (how a web page looks)
- Back-end - server-side (how a web page works)

• טכנולוגיות צד שרת

- Server-Side Technologies:
 - PHP, ASP
 - Node.js (JavaScript)
 - Django (Python)

• עיבוד הבקשה נעשה בצד השרת

- <https://www.w3schools.com/>

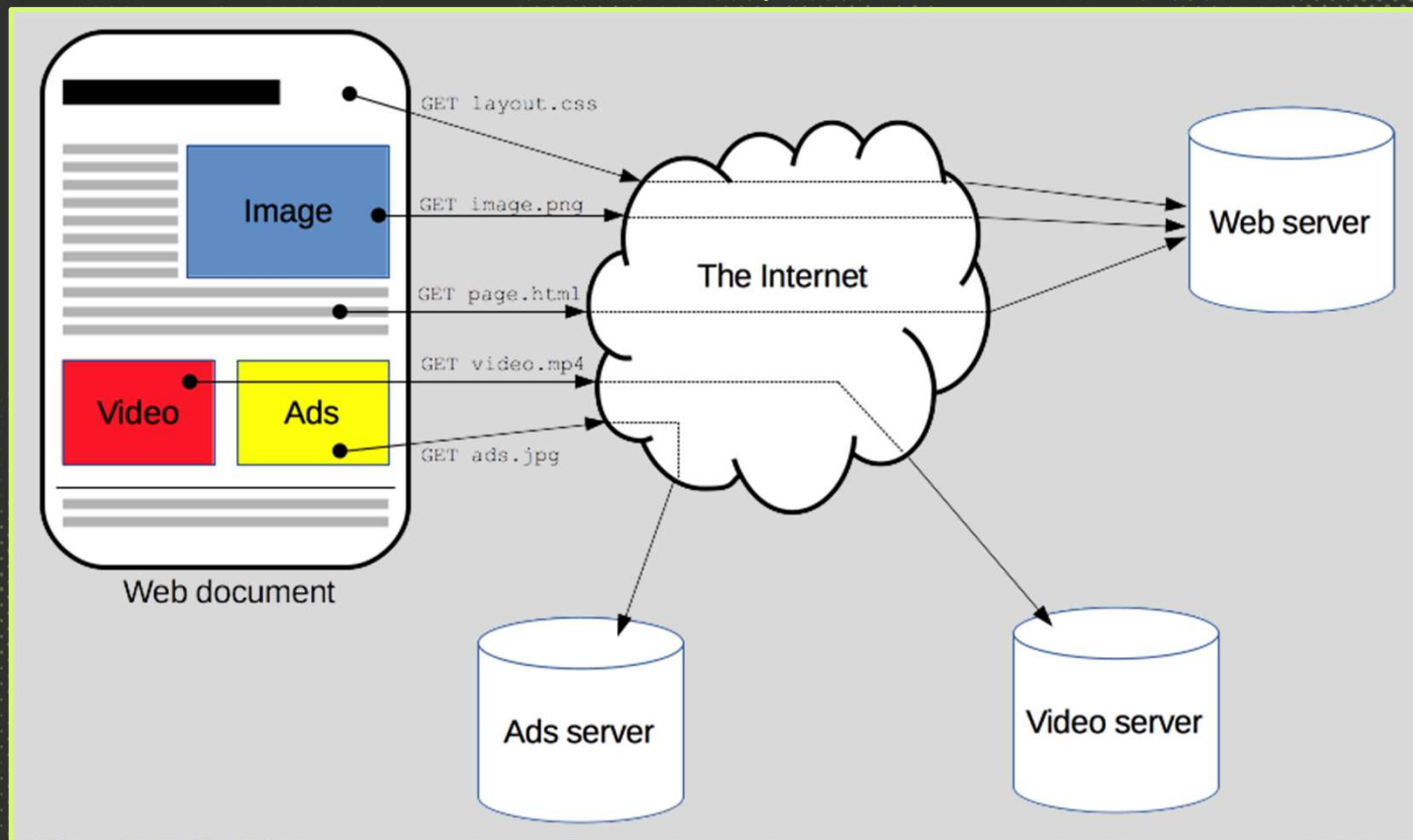
פרוטוקול - HTTP

Hypertext Transfer Protocol (HTTP)

הפרוטוקול שמניע את האינטרנט

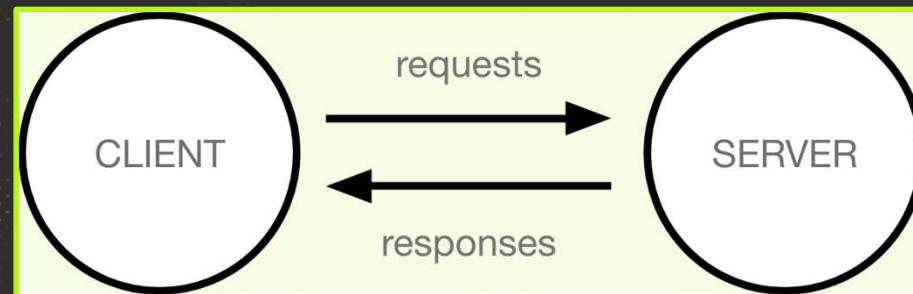


פרוטוקול HTTP



פרוטוקול HTTP - מודל שרת-לקוח

- מודל שרת-לקוח
- Stateless, but not Session-less
- הודעות: בקשה <-> תשובה
- מידע נשלח "כ-טקסט" (ASCII)



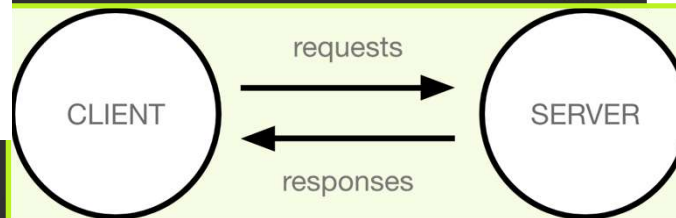
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/>

HTTP Protocol

Method Path Protocol version

```
GET / HTTP/1.1
Host: developer.mozilla.org
Accept-Language: fr
```

Headers



Responses are grouped in five classes:

1. Informational responses (100 – 199)
2. Successful responses (200 – 299)
3. Redirection messages (300 – 399)
4. Client error responses (400 – 499)
5. Server error responses (500 – 599)

Protocol version Status code Status message

```
HTTP/1.1 200 OK
date: Tue, 18 Jun 2024 10:03:55 GMT
cache-control: public, max-age=3600
content-type: text/html
```

Headers

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Overview>

HTTP Protocol (in Wireshark)

No.	Time	Source	Destination	Protocol	Length	Info
5	0.224248	2a00:a041:e0f5:3a00...	2600:1406:bc00:53::...	HTTP	149	GET / HTTP/1.1
6	0.416984	23.220.75.245	192.168.1.244	TCP	66	80 → 61439 [SYN,
7	0.441104	2600:1406:bc00:53::...	2a00:a041:e0f5:3a00...	TCP	74	80 → 61438 [ACK]
8	0.444887	2600:1406:bc00:53::...	2a00:a041:e0f5:3a00...	TCP	1514	80 → 61438 [ACK]
9	0.444887	2600:1406:bc00:53::...	2a00:a041:e0f5:3a00...	HTTP	152	HTTP/1.1 200 OK
10	0.445165	2a00:a041:e0f5:3a00...	2600:1406:bc00:53::...	TCP	74	61438 → 80 [ACK]

> Frame 5: 149 bytes on wire (1192 bits), 149 bytes captured (1192 bits) on interface
> Ethernet II, Src: Intel_cf:e5:fe (64:49:7d:cf:e5:fe), Dst: AlticeLabs_24:46:cf (68
> Internet Protocol Version 6, Src: 2a00:a041:e0f5:3a00:1983:58b1:a767:c892, Dst: 26
> Transmission Control Protocol, Src Port: 61438, Dst Port: 80, Seq: 1, Ack: 1, Len:
✓ Hypertext Transfer Protocol
 > GET / HTTP/1.1\r\n
 Host: example.com\r\n
 User-Agent: curl/8.14.1\r\n
 Accept: */*\r\n
 \r\n
 [Response in frame: 9]
 [Full request URI: http://example.com/]

0000 68 aa
0010 bb 11
0020 58 b1
0030 00 00
0040 3f aa
0050 48 54
0060 65 78
0070 72 2d
0080 31 34
0090 2a 0d

מבט מלמעלה אבטחת מערכות תקשורת

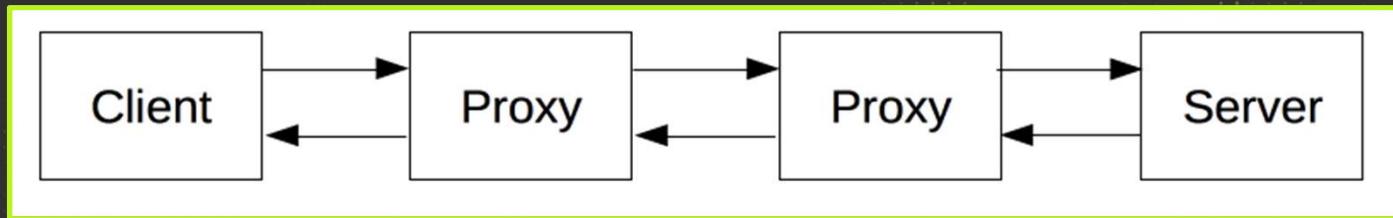
Network Security in 2 minutes



רכיבי תקשורת ואבטחה HTTP

• רכיבים שלא מנתחים תעבורת HTTP

- Firewall
- Router (נתב)
- Network Load Balancer



• רכיבים המנתחים תעבורת HTTP

- Proxy
- Application Load Balancer
- Web Cache
- WAF — Web Application Firewall
- Web Server

Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב (Web Security)
- חולשה נפוצה + מעבדה עצמית
- מקורות תרגול והעשרה

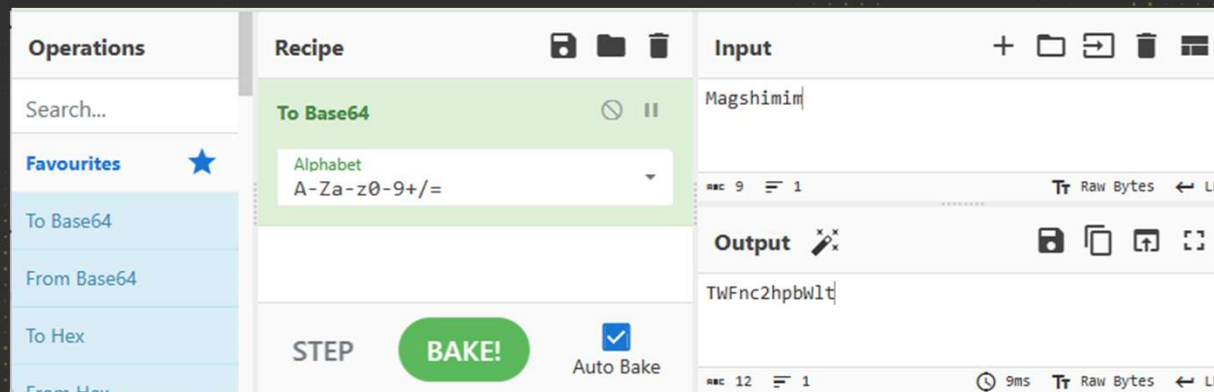
כלים לפיתוח ומחקר ווב

Tools & Demos



Base64 Encoding (+ CyberChef)

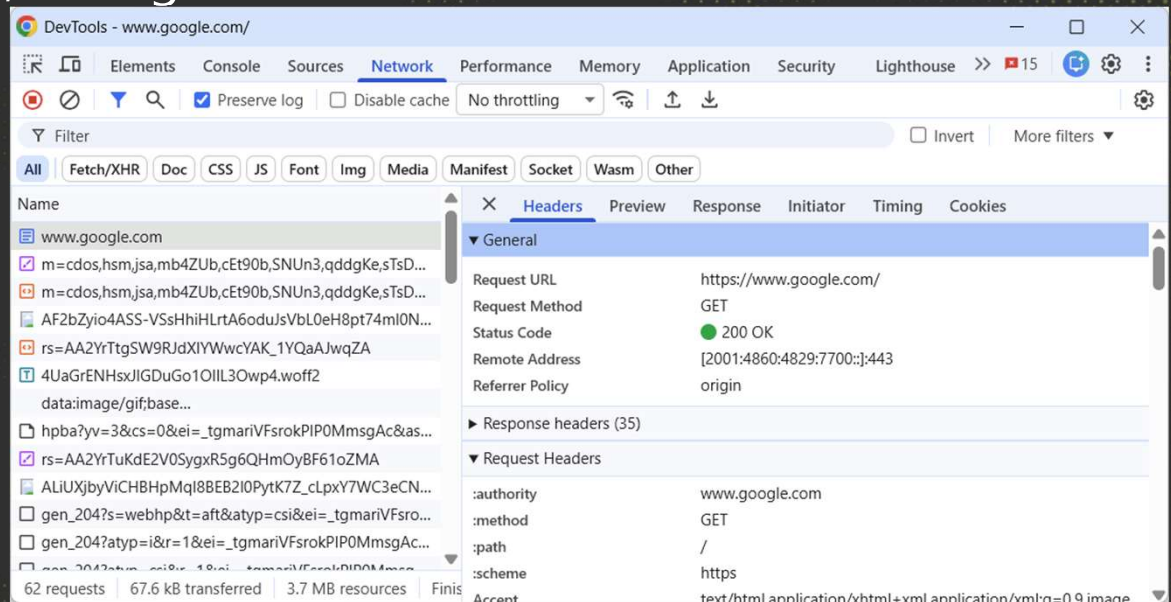
- קידוד - Base64
- מיועד להעברת מידע בינארי על גבי ערוץ שתומך בטקסט בלבד (תווי אסקי-Ascii)
- משמש לשליחת צרופות (קבצים) בשליחת מיילים (SMTP)



- <https://en.wikipedia.org/wiki/Base64>
- [https://gchq.github.io/CyberChef/#recipe=To Base64\('A-Za-z0-9%2B/%3D'\)&input=TWFnY2hpbWlt](https://gchq.github.io/CyberChef/#recipe=To%20Base64('A-Za-z0-9%2B/%3D')&input=TWFnY2hpbWlt)

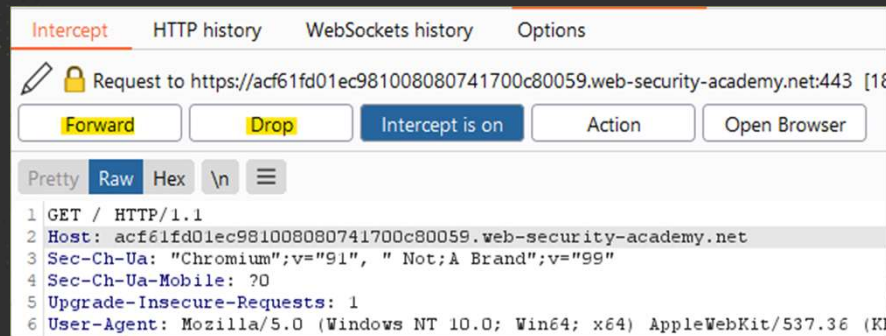
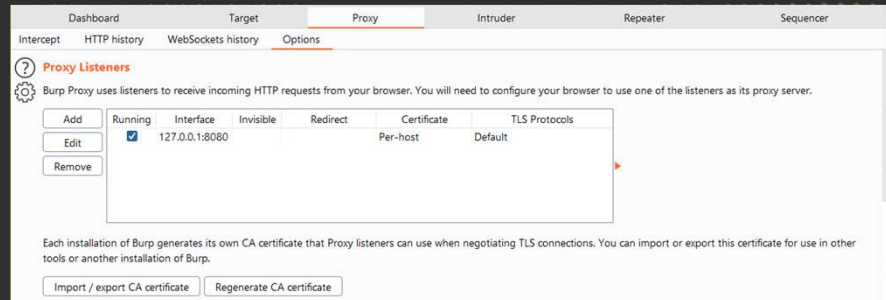
Browser DevTools — Demo

- **Elements** - inspect DOM
- **Console** - page interaction, JS
- **Application** — cookies, storage
- **Sources**
 - debug JS
- **Network**
 - inspect requests
 - Copy As (fetch)



Tools – Burp Suite (Community)

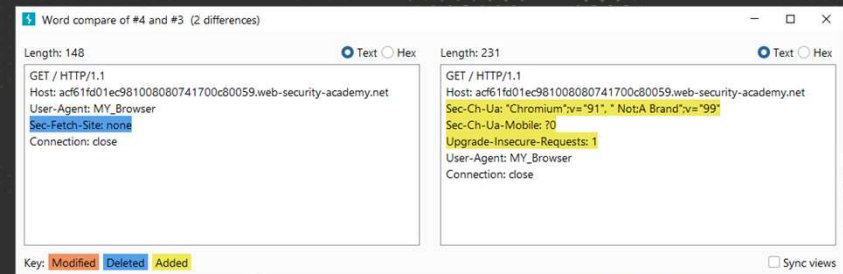
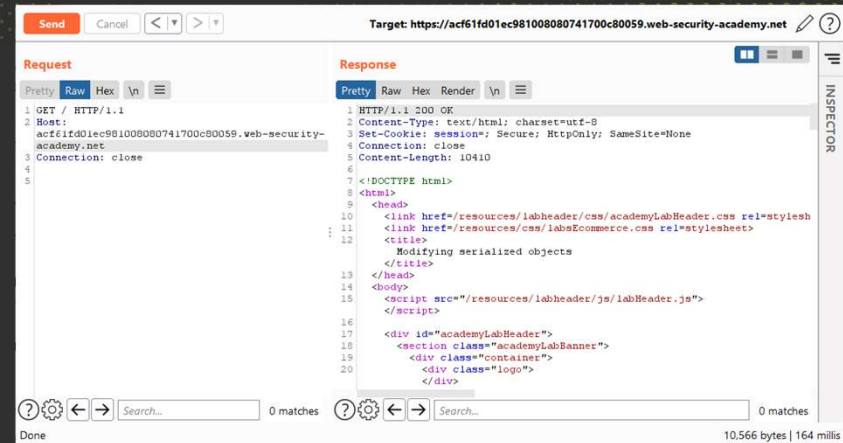
- Host Proxy
- Dashboard
- Target
- Proxy
 - Intercept
 - HTTP History
 - Options



- <https://portswigger.net/burp/communitydownload>

Burp Suite Cont'

- Repeater (Ctrl + R)
 - עריכה ושליחה ידנית
- Intruder (Ctrl + I)
 - הגדרת "משתנים" וערכי Payload לשליחה אוטומטית
- Decoder
 - פענוח קידודים
- Comparer
 - השוואה בין בקשות
- Extender
 - הורדת וניהול "הרחבות"



Demo

- Lab Demo
- [Lab: Unprotected admin functionality | Web Security Academy](#)

סיכום כלים — Tools

כלי	קישור
CyberChef	https://gchq.github.io/CyberChef/
Burp Suite	https://portswigger.net/burp/communitydownload
*OWASP ZAP	https://www.zaproxy.org/
*Fiddler	https://www.telerik.com/fiddler/fiddler-classic
Browser DevTools	built-in

Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב (Web Security)
- חולשה נפוצה + מעבדה עצמית
- מקורות תרגול והעשרה

Web Security



רגע לפני — אחריות וחוק המחשבים

- חוק המחשבים, התשנ"ה – 1995
- חוק המחשבים – קישור
- בכל מקרה - חובה להשיג אישור בכתב של בעל הנכס
- לשים לב שלא חורגים מהנכסים שהוגדרו
- לדוגמא: שרתים משותפים, שירותי אחסון

Web Security — Resources



מקורות לימוד – Web Security

קישור	מקור
https://owasp.org/	OWASP
https://owasp.org/Top10/	OWASP Top Ten
https://owasp.org/www-project-web-security-testing-guide/v42/	OWASP WSTG
https://portswigger.net/web-security/learning-path	PortSwigger Academy

PortSwigger — Web Security Academy

• כל הנושאים

- <https://portswigger.net/web-security/all-topics>

• מסלולים (Learning Paths)

- <https://portswigger.net/web-security/learning-path>
- <https://portswigger.net/web-security/learning-paths/server-side-vulnerabilities-apprentice>

Web Security – Resources – Portswigger – חקורות

Client-side topics

Client-side vulnerabilities introduce an additional layer of complexity, which can make them slightly more challenging. These materials and labs will help you build on the server-side skills you've already learned and teach you how to identify and exploit some gnarly client-side vectors as well.

Cross-site scripting (XSS)

Simply put, XSS is one of the most important vulnerabilities out there. It's both incredibly common and extremely powerful, especially when used as part of a wider exploit chain. This is a huge topic, with plenty of labs for complete beginners and seasoned pros alike.

[Go to topic →](#) 30 Labs

Cross-site request forgery (CSRF)

[Go to topic →](#) 12 Labs

Cross-origin resource sharing (CORS)

[Go to topic →](#) 4 Labs

Clickjacking

[Go to topic →](#) 6 Labs

DOM-based vulnerabilities

[Go to topic →](#) 7 Labs

WebSockets

[Go to topic →](#) 3 Labs

Server-side topics

For complete beginners, we recommend starting with our server-side topics. These vulnerabilities are typically easier to learn because you only need to understand what's happening on the server. Our materials and labs will help you develop some of the core knowledge and skills that you will rely on time after time.

SQL injection

SQL injection is an old-but-gold vulnerability responsible for many high-profile data breaches. Although relatively simple to learn, it can potentially be used for some high-severity exploits. This makes it an ideal first topic for beginners, and essential knowledge even for more experienced users.

[Go to topic →](#) 16 Labs

Authentication

[Go to topic →](#) 14 Labs

Path traversal

[Go to topic →](#) 6 Labs

Command injection

[Go to topic →](#) 5 Labs

Business logic vulnerabilities

[Go to topic →](#) 11 Labs

Information disclosure

[Go to topic →](#) 5 Labs

Access control

[Go to topic →](#) 13 Labs

File upload vulnerabilities

[Go to topic →](#) 7 Labs

Race conditions

[Go to topic →](#) 6 Labs

Server-side request forgery (SSRF)

[Go to topic →](#) 7 Labs

XXE injection

[Go to topic →](#) 9 Labs

NoSQL injection

[Go to topic →](#) 4 Labs

API testing

[Go to topic →](#) 5 Labs

- PortSwigger - Web Security Academy
- <https://portswigger.net/web-security/all-topics>

חקורות – Portswigger – Resources – Web Security

Advanced topics

These topics aren't necessarily more difficult to master but they generally require deeper understanding and a wider breadth of knowledge. We recommend getting to grips with the basics before tackling these labs, some of which are based on pioneering techniques discovered by our world-class research team.

Insecure deserialization

Deserialization has a reputation for being difficult to get your head around but it can be much easier to exploit than you might think. We'll guide you through the process step-by-step so you can pick off some high-severity bugs that even experienced testers may have missed altogether.

[Go to topic →](#)

10 Labs

Web LLM attacks

New topic

[Go to topic →](#)

4 Labs

GraphQL API vulnerabilities

[Go to topic →](#)

5 Labs

Server-side template injection

[Go to topic →](#)

7 Labs

Web cache poisoning

[Go to topic →](#)

13 Labs

HTTP Host header attacks

[Go to topic →](#)

7 Labs

HTTP request smuggling

[Go to topic →](#)

22 Labs

OAuth authentication

[Go to topic →](#)

6 Labs

JWT attacks

[Go to topic →](#)

8 Labs

Prototype pollution

[Go to topic →](#)

10 Labs

Essential skills

[Go to topic →](#)

2 Labs

Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב
- חולשה נפוצה + מעבדה עצמית
- מקורות תרגול והעשרה

Insecure Deserialization

חולשה - פתיחה לא מאובטחת של רצף סדרתי



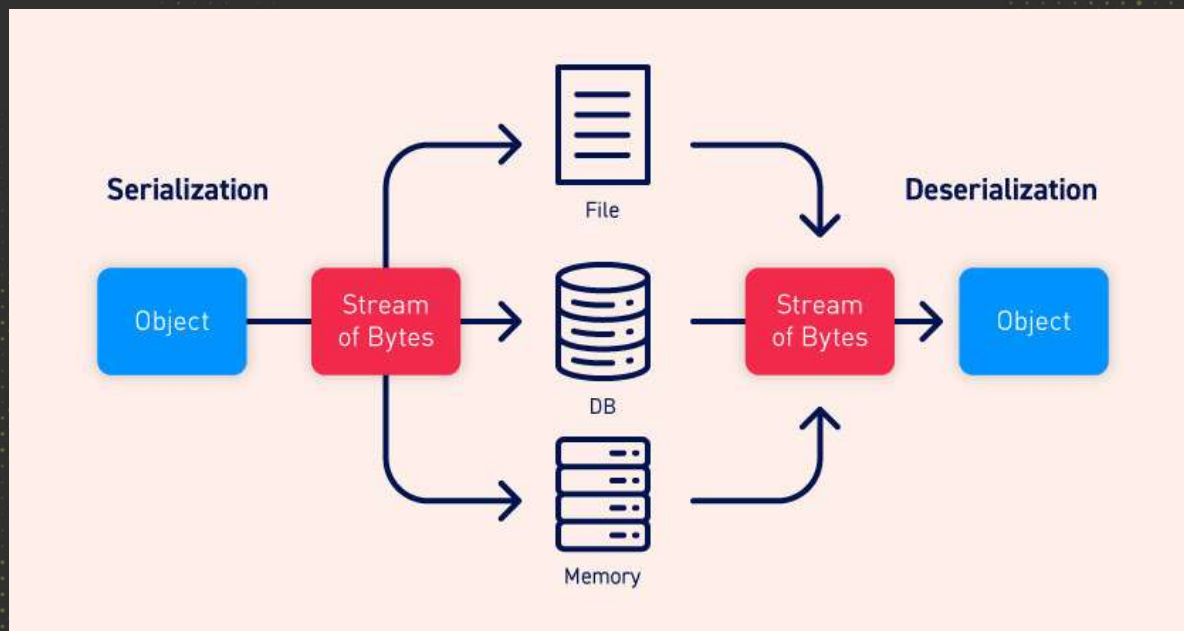
Insecure Deserialization — חקירות

- OWASP Top 10:
 - [https://owasp.org/www-project-top-ten/2017/A8_2017-Insecure Deserialization](https://owasp.org/www-project-top-ten/2017/A8_2017-Insecure_Deserialization)
- OWASP Cheat Sheet:
 - [https://cheatsheetseries.owasp.org/cheatsheets/Deserialization Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Deserialization_Cheat_Sheet.html)
- PortSwigger Academy:
 - <https://portswigger.net/web-security/deserialization>

Insecure Deserialization

- What is serialization?
- Serialization vs deserialization

- מהי סריאליזציה ?
- דיסריאליזציה



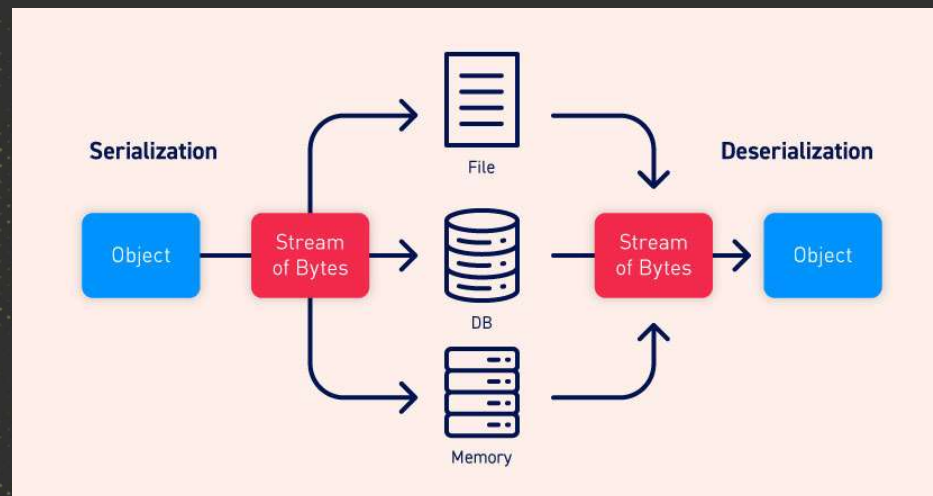
מהי סריאליזציה?

- **Serialization**

- המרת אובייקט לפורמט שניתן לשמור/לשלוח

- **Deserialization**

- שחזור האובייקט מהפורמט



Insecure Deserialization – PHP serialize function

serialize

(PHP 4, PHP 5, PHP 7, PHP 8)

serialize — Generates a storable representation of a value

Description

```
serialize(mixed $value): string
```

Generates a storable representation of a value.

This is useful for storing or passing PHP values around without losing their type and structure.

To make the serialized string into a PHP value again, use [unserialize\(\)](#).

- <https://www.php.net/manual/en/function.serialize.php>

פורמט הסריאליזציה של PHP

- פורמט מבוסס טקסט
- אותיות מייצגות את סוג המשתנה (Data Type)
- מספרים מייצגים אורך של השדה המקודד

מחל	משמעות
s	string
i	integer
b	boolean
a	array
O	object

```
$user->name = "carlos";  
$user->isLoggedIn = true;
```

When serialized, this object may look something like this:

```
O:4:"User":2:{s:4:"name":s:6:"carlos"; s:10:"isLoggedIn":b:1;}
```

Insecure Deserialization – PHP unserialize function

unserialize

(PHP 4, PHP 5, PHP 7, PHP 8)

unserialize — Creates a PHP value from a stored representation

Description

```
unserialize(string $data, array $options = []): mixed
```

`unserialize()` takes a single serialized variable and converts it back into a PHP value.

Warning Do not pass untrusted user input to `unserialize()` regardless of the `options` value of `allowed_classes`. Unserialization can result in code being loaded and executed due to object instantiation and autoloading, and a malicious user may be able to exploit this. Use a safe, standard data interchange format such as JSON (via `json_decode()` and `json_encode()`) if you need to pass serialized data to the user.

If you need to unserialize externally-stored serialized data, consider using `hash_hmac()` for data validation. Make sure data is not modified by anyone but you.

- <https://www.php.net/manual/en/function.unserialize.php>
- Demo: <https://www.programiz.com/php/online-compiler/>

מהי חולשת "פענוח לא בטוח" ?

- What is insecure deserialization?

• מהי חולשת "פענוח לא בטוח" ?

• המידע לפיענוח נשלט ע"י המשתמש (או תוקף)

• אף ניתן לשחזר (לייצר) אובייקט מסוג אחר

- ⚠ **User-controlled input + deserialization = vulnerability**

- <https://portswigger.net/web-security/deserialization/exploiting>

כיצד נזהה חולשות "פענוח לא בטוח" ?

- סטטי - סקר קוד
- חיפוש שמות פונקציות
- וכד', unserialize, pickle.loads, ObjectInputStream,
- דינאמי - מבדק חדירות
- זיהוי פורמט סריאליזציה בתעבורה
- בדיקה אם ניתן לשלוט בערכים שנשלחים
- [Deserialization - OWASP Cheat Sheet Series](https://portswigger.net/web-security/deserialization/exploiting)
- <https://portswigger.net/web-security/deserialization/exploiting>

Exploiting Insecure Deserialization Vulnerabilities

[Live exploitation demonstration]



Lab — Insecure Deserialization

Lab Time!

<https://portswigger.net/web-security/deserialization/exploiting/lab-deserialization-modifying-serialized-objects>



כיצד נוצרות החולשות?

- חוסר הבנה - עד כמה מסוכן יכול להיות מידע שנשלט ע"י המשתמש
- הנחה שקוד עם בדיקת שגיאות הוא בטוח
- הנחה שאובייקטים מסורלזים (מקודדים) הם בטוחים
- במיוחד כאשר פורמט הסריאליזציה הוא בינארי

כיצד נמנע מהחולשה ? (הגנות)

• להימנע ככל הניתן מדיסריאליזציה של תוכן שנשלט ע"י משתמש

- Integrity checks

- יישום בדיקות אמינות

- Type enforcement

- אכיפת מגבלות סוג אובייקט בתהליך הפתיחה

- Sandboxing

- הרצת קוד הפתיחה בסביבה בעלת הרשאות נמוכות

- <https://owasp.org/www-pdf-archive/OWASP-Top-10-2017-he.pdf>

Insecure Deserialization — CVEs האחריות

- <https://cve.mitre.org/cgi-bin/cvekey.cgi?keyword=deserialization>
- <https://www.cvedetails.com/vulnerability-list/cwe-502/vulnerabilities.html>

Resources & Next Steps

Practice · Socialize · Level Up



Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב
- חולשה נפוצה + מעבדה עצמית
- מקורות תרגול והעשרה

תרגול — Web Security

קישור	פלטפורמה
https://www.picoctf.org/	PicoCTF
https://overthewire.org/wargames/	OverTheWire (Bandit + Natas)
https://portswigger.net/web-security/all-labs	PortSwigger Labs
https://code.google.com/archive/p/owaspbwa/	OWASP BWA (Offline)
https://www.hackthebox.eu/	HackTheBox

אירועים וחפגשים — Socialize

אירוע	קישור	YouTube
OWASP Israel Meetup	https://www.meetup.com/OWASP-Israel/	@owaspisrael4292
BSides TLV	https://bsidestlv.com/	@BSidesTLV
Intent Summit (CyberArk)	https://intentsummit.org/	@intentsecurityresear chsumm634
BlueHat IL (Microsoft)	https://www.microsoftrnd.co.il/BluehatIL/home	@microsoftrndIsrael
DEF CON	https://defcon.org/	DEFCONConference
Black Hat (USA + more)	https://www.blackhat.com/	@BlackHatOfficialYT
Hackeriot	https://www.hackeriot.org/	@hackeriot

• התנדבות?
• התנדבות!

• הקלטות?
• הקלטות!

תחרויות ותוכניות חיפוש חולשות - CTF & Bug Bounty

- CTF — My Two Cents:

- נסו לבד

- רשמו מה ניסיתם

- לאחר התחרות! Write-ups!

- CTF Calendar:

- <https://ctftime.org/calendar/>

- Bug Bounty Platforms:

- <https://hackerone.com/bug-bounty-programs>

- <https://www.bugcrowd.com/bug-bounty-list/>

- <https://www.intigriti.com/>

BlueHat IL - 24.06.26

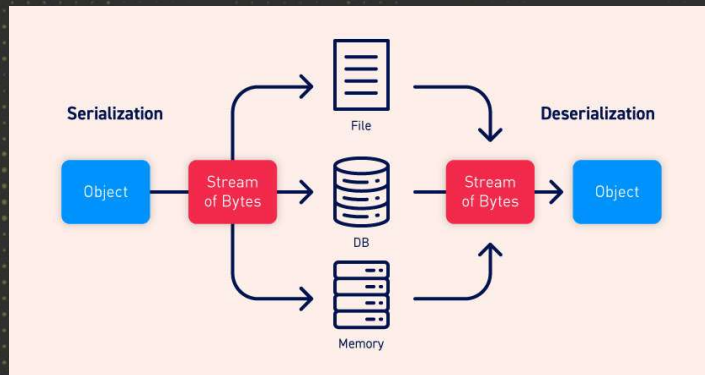
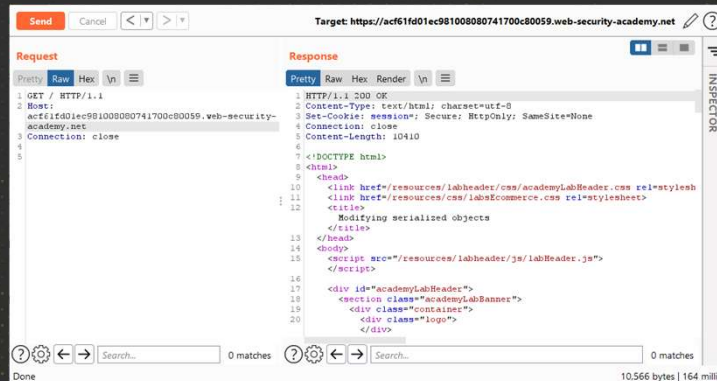
מוזמנים להרשם!

<https://www.microsofttrnd.co.il/bluehatil/conference/abstracts#collapse-12>

Summary



סיכום



- רקע תיאורטי
- פרוטוקול – HTTP
- כלים שימושיים
- מנגנון סריאליזציה ודיסריאליזציה
- מימוש המנגנון בשפת PHP
- חולשת "פענוח לא בטוח"
- זיהוי וניצול החולשה
- מניעה והתגוננות
- מקורות להעשרה

Questions ?

Thank You!

These Slides:

<https://github.com/m2a2/Magshimim>

My Research

<https://github.com/m2a2/Research>

Contact me on LinkedIn:

<https://il.linkedin.com/in/maor-abutbul>



Extra

Offline reads



Read more at our blog posts & Thank you

"Let's Be Authentik: You Can't Always Leak ORMs"

<https://www.cyberark.com/resources/threat-research-blog/lets-be-authentik-you-cant-always-leak-orms>



"You Can't Always Win Racing the (Key)cloak"

<https://www.cyberark.com/resources/threat-research-blog/you-cant-always-win-racing-the-keycloak>



Read more at our blog posts & Thank you

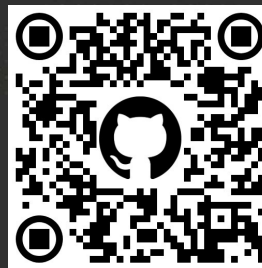
"Fuzzing and Racing HTTP/3: Open-Sourcing QuicDraw(H3)"

<https://www.cyberark.com/resources/threat-research-blog/racing-and-fuzzing-http-3-open-sourcing-quicdraw>



QuicDraw & QuicDraw-UI Repo:

<https://github.com/cyberark/QuicDrawH3>



כלים נוספים שכדאי להכיר — Extra Tools

קטגוריה	כלים
עריכת קוד	Notepad++, VSCode, claude
רשת	Wireshark, Tshark, Nmap, Netcat
CLI	ping, traceroute, curl, wget, openssl
Linux	cat, grep, sort, wc, jq, ls
Python	Requests, BeautifulSoup4, Selenium
וירטואליזציה	VirtualBox, VMware, Docker
שונות	PuTTY, 7Zip, Git & GitHub

Web Technologies — חקרונות נוספים

W3Schools & MDN:

- <https://www.w3schools.com/>
- <https://developer.mozilla.org/en-US/docs/Web>

Web Security:

- <https://developer.mozilla.org/en-US/docs/Web/Security>
- Same-Origin Policy: https://developer.mozilla.org/en-US/docs/Web/Security/Same-origin_policy

מקורות נוספים — HTTP Messages

- Overview: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Overview>
- Methods: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Methods>
- Authentication: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Authentication>
- Messages: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Messages>